Testing Status & Issues

> Analysis of commit `8de48cf` (branch `main`). No production code was changed to produce this document.
>
> **Classification** used for every finding:
>
> - **Confirmed issue**: the defect follows directly from code that was read.
> - **Potential issue**: plausible from the code, but needs a runtime check.
> - **Missing implementation**: a feature the UI, schema or comments imply, but the code does not do.
> - **Improvement recommendation**: not a bug; a change that would improve the code.
>
> **Verification marks**: ✔ = re-checked line by line during the final review of this document; all other findings come from the module-by-module code trace, with the file:line evidence shown.

1. What was actually run

Check	Command	Result (2026-10-27)
Type check (web + api)	`npm run typecheck`	**Pass**: no errors
Lint (web + api, `--max-warnings 0`)	`npm run lint`	**Pass**
API unit tests	`cd apps/api && npm test` (node:test + tsx, mocked Prisma)	**189 / 189 pass**, 60 suites
Web unit tests	`cd apps/web && npx vitest run`	**539 / 539 pass**, 67 files
Playwright mock suite	`apps/web: npm run e2e` (VITE_USE_MOCKS=1)	**Not run**
Real-API end-to-end	`node tests/e2e.mjs`, `node tests/admin-e2e.mjs`	**Not run**: both seed and mutate a live database; deliberately skipped
BillDesk stub	`node tests/billdesk-stub.mjs`	**Not run** (and incompatible with the current webhook route; see P-02)

Passing unit tests do **not** demonstrate that the workflows in this document work end to end. They run against mocked Prisma and mocked HTTP. None of the workflows were exercised against a running API in this analysis.

2. Test estate

Layer	Location	Size	What it covers
API unit	`apps/api/src/**/*.test.ts`	16 files	auth (login, refresh rotation, OTP, register, reset), admin service (users, employer approval, job moderation, settings), Q1 completeness/priority, jobs search, education validation, key skills, avatar, site docs, SSE fan-out, hiring/matching helpers, PDF page count, one Q3 document-scope test, CV expiry
Web unit	`apps/web/src/**/*.test.{ts,tsx}` (Vitest + jsdom)	64–67 files	UI primitives, auth store/types, ProtectedRoute, Q1 rail/modal, Q2 detail page, formatters, hooks, lib helpers
Playwright (mocked API)	`apps/web/e2e/*.spec.ts`	43 specs, ~300 tests	Q1/Q2 workspaces, legacy recruitment screens, admin dashboard + approvals, candidate flows, employer registration/job post, public pages, a11y, PWA, responsive
Real-API crawl	`tests/e2e.mjs`	115 lines	Every public page and each of 6 roles' pages; fails on console errors, API ≥400, 404 page
Real-API admin suite	`tests/admin-e2e.mjs`	404 lines	Admin access control, user/job/employer actions against the DB, audit, responsive widths 320–1440 px
CI	`.github/workflows/ci.yml`	5 jobs	static (typecheck, lint, unit, build), e2e-mock, e2e (real Postgres + Redis), docker build, deploy (main → EC2 over SSH)

2.1 Critical paths with no automated tests

#	Path	Why it matters
T-1	Payments: Razorpay order/verify/webhook, BillDesk settle, idempotency, amount check	Money; the BillDesk settle path is already unreachable (P-02)

#	Path	Why it matters
T-2	Employer job lifecycle and applicant decisions (`employers.service.ts` , 2.7k lines, no tests)	Core employer workflow
T-3	`q2.service.ts` transitions (forward, send back, reject)	Pipeline correctness
T-4	Q3 services: round setup, confirm, decide, offer, joined, return/expire	Pipeline correctness; the two decision engines disagree (W-01)
T-5	File access control (`/files/*` , `/recruitment/*/resume` , `/recruitment/documents/:id/file`)	Personal data exposure (S-01)
T-6	Role matrix per endpoint (no test enumerates `@Roles`)	Would have caught the Q3 legacy 403s (F-02)
T-7	axios refresh / CSRF / 429 interceptors	Session handling
T-8	Email/BullMQ delivery and SSE auth	Notifications
T-9	`/q3/*` workspace and admin user/job/settings/blog/reports/audit actions in the Playwright mock suite	New screens untested in-browser except via the real-API crawl

2.2 Test-quality findings

- **Confirmed issue**: two "API contract" specs only assert their own mocks (`apps/web/e2e/offer-letter.spec.ts:18-64, 90-111` ; `video-meeting-link.spec.ts:30-51`).
- **Confirmed issue**: CI runs the web unit tests twice and lints twice, the second time with a looser threshold (`.github/workflows/ci.yml` , static job).
- **Confirmed issue**: there are duplicate unit-test files for Alert, Button, Input, Pagination, `cn` and `tokenStorage` , and two Vitest configs (`apps/web/vitest.config.ts` and a dead `test` block in `apps/web/vite.config.ts`).
- **Potential issue**: `tests/e2e.mjs` waits with `waitUntil: 'networkidle'` while the SSE stream is open. Each navigation probably runs to the timeout. Project memory also says to avoid networkidle.
- **Potential issue**: `tests/e2e.mjs` skips the `/recruitment/q3/*` pages, which is why F-02 is not caught.
- **Potential issue**: the Playwright suite mocks the API with `page.route` , so request-shape bugs such as array query params (F-04) are invisible to it.

---

3. Findings by severity

3.1 Security & personal-data exposure

ID	Class	Finding	Evidence
S-01 ✔	Confirmed issue	**Any signed-in user can download any stored file by key.** `GET /api/files/:folder/:sub/:name` has no `@Roles` and no ownership check. Keys reach employers (applicant `documentPath`), Q2 (`latestCVPath`), upload responses and audit rows.	`apps/api/src/modules/files/files.controller.ts:63-77` ; `employers.service.ts:2494` ; `q2.service.ts:851`
S-02	Confirmed issue	**Arbitrary file exposure through the public logo endpoint.** `PATCH /clients/me` accepts any string as `companyLogo` , and the registration's free-text logo is copied on approval. `GET /api/clients/:id/logo` is public and streams that storage key.	`employers/dto/employers.dto.ts:599-602` ; `employers.service.ts:409-428, 444` ; `admin.service.ts:1345`
S-03	Confirmed issue	**Employer document access is scoped to the candidate, not the application.** Company A sees, and can approve or flag, documents collected for company B's application.	`employers.service.ts:2483-2505, 2536-2540`
S-04	Confirmed issue	**Unescaped user input in HTML emails** (welcome: fullName; application-status: fullName, message; interview-scheduled: location (also used as an `href`), interviewer, notes, job title, company).	`apps/api/src/common/email/templates/welcome.template.ts:12` , `application-status.template.ts:61` , `interview-scheduled.template.ts:35-60`
S-05	Confirmed issue	**Access tokens are not revocable.** The guard trusts the token's `roleId` for its TTL (default 15 min) and ignores logout, deactivation and role changes.	`apps/api/src/common/guards/jwt-auth.guard.ts:37-52`
S-06	Confirmed issue	**The CSRF token is issued and sent, but never validated** (bearer auth makes it largely moot, so it is dead weight).	`apps/api/src/modules/auth/csrf.controller.ts` ; `apps/web/src/lib/axios.ts:38-44`
S-07	Potential issue	**Unscoped access to identity documents.** QC1/QC2 can list and download every candidate's identity documents (Aadhaar, PAN, bank) and verify or reject them. Q3's equivalent is scoped.	`recruitment.controller.ts:103-128` ; contrast `q3-documents.service.ts:78-84`
S-08	Potential issue	**Q3 can act on any application through `/recruitment/*` .** It can create rounds, results, offers and joined status on applications never referred to it (`MappingAccessService` checks Candidate and Client only).	`apps/api/src/modules/recruitment/mapping-access.service.ts:24-69`

ID	Class	Finding	Evidence
S-09	Potential issue	**Employers see and can act on applicants before the QC1→QC2→Q3 pipeline releases them.** This includes full contact details and the ability to shortlist, hire or interview; undo can also reverse a staff rejection. Needs a product decision.	`employers.service.ts:734-777, 1297-1401`
S-10	Confirmed issue	**The employer approval email contains the temporary password in plain text**, and nothing forces it to be changed (`pwdStatus` is never read; employers and staff have no change-password endpoint).	`admin.service.ts:1384-1394` ; `auth.service.ts` (no pwdStatus read)
S-11	Confirmed issue	**Logout does not clear the React Query cache, offline queue or last order ref.** A second user on the same tab can briefly see the previous user's cached data.	`apps/web/src/features/auth/auth.store.ts:35-41` ; no `queryClient.clear()` anywhere
S-12	Improvement recommendation	**Session and secret handling.** The refresh token is in localStorage. The log email driver writes OTPs and reset links to the logs. The 2Factor key goes in the URL path. Login lockout is per-IP only (5/min). Draft, Closed and Archived jobs are publicly readable by id. The public avatar route allows enumerating photos by sequential id.	`apps/web/src/lib/tokenStorage.ts:18` ; `notifications/providers/log.provider.ts:19` ; `twofactor.provider.ts:15` ; `jobs.service.ts:508-521` ; `files.controller.ts:151-170`
S-13	Confirmed issue	**A fallback SQL Server SA password is committed in source** (value intentionally not reproduced).	`apps/api/prisma/migrate-data.ts:32`

3.2 Broken or incomplete workflows

ID	Class	Finding	Evidence
W-01	Confirmed issue	**Two round-result engines disagree.** `InterviewRoundService.submitResult` (employer portal and `/recruitment`) never sets `decision` , `isFinal` , `selectedAt` or `conductedAt` , which Q3's stage logic relies on. After an employer "Hire", Q3 still shows "Decision" and accepts a contradicting second decision, and the documents/offer flow never starts. Hold → ON_HOLD (employer) vs no status change (Q3). A recruitment "final round" (roundNumber 4, isFinal=false) can never be Selected by Q3.	`recruitment/interview-round.service.ts:299-415` ; `q3/q3-interviews.service.ts:580-660` ; `shared/hiring.ts:331`
W-02	Confirmed issue	**`transitionStatus` has no from-state guard.** `PATCH /recruitment/pipeline/:id` sets any status with no log, history or audit, and QC1 can call it (no web caller). `selectSlot` , `addSlots` , `submitResult` and `sendOffer` lack status preconditions; for example, a candidate can re-select a slot on a completed round, and a resent offer reopens an accepted one.	`jobs/job-application.service.ts:167` ; `recruitment.service.ts:503` ; `interview-round.service.ts:153-229, 299` ; `offer-letter.service.ts:97`
W-03	Confirmed issue	**Q1 → Q2 hand-offs are not enforced.** Q1 "Verified" gates nothing (Q2 lists every application on active jobs), and a Q2 "send back" is a dead end: nothing returns the application to Q2.	`q2.service.ts:595-648, 975-987` ; `q1.service.ts:485`
W-04	Confirmed issue	**Company rejection marks the referral `Returned` without `returnedAt` .** The Q3 badge counts it while the Returned list omits it, and the CV can be re-referred.	`cv-referral.service.ts:441-449` ; `employers.service.ts:1359-1365` ; `q3-referrals.service.ts:392` ; `q3-read.service.ts:582-585`
W-05	Confirmed issue	**An auto-expired CV is back in Q2's queue, but its status stays 23 CV_EXPIRED** (shown as Closed by admin). A manual return moves it to 1 MAPPED.	`cv-referral.service.ts:216-300`
W-06	Confirmed issue	**The two "mark joined" paths disagree.** `/recruitment/offers/:id/mark-joined` does not set `ApplicationHiring.joinedAt` , so Q3 keeps the application in the Offer stage and the quarterly report misses it.	`offer-letter.service.ts:190` ; `q3-documents.service.ts:429`
W-07	Confirmed issue	**Shortlisting gives different statuses by path**: Q3 round-setup → 2 SHORTLISTED; employer interview request or recruitment company-review → 16 INTERVIEW_R1.	`q3-referrals.service.ts:365` ; `interview-round.service.ts`
W-08	Missing implementation	**There is no application withdrawal.** Statuses 8 RESCHEDULED, 12 DUPLICATE and 13 WITHDRAWN are never written, and the candidate has no withdraw or reschedule UI.	grep: no writer
W-09	Confirmed issue	**An offer rejection leaves the application at 20 OFFER_SENT** (there is no closed status). Offer creation checks *all* of the candidate's uploads, across applications.	`offer-letter.service.ts:38-47, 153-159`
W-10	Confirmed issue	**Document-request de-duplication is per candidate, not per application**, so company A's document approval may never complete when company B already requested the same type. Document status 3 (NeedsCorrection) is shown as "Pending".	`employers.service.ts:2663-2668, 2495, 2542`
P-01	Confirmed issue	**Razorpay checkout fails in the Docker deploy.** No compose file forwards `RAZORPAY_KEY_ID` , `RAZORPAY_KEY_SECRET` or `RAZORPAY_WEBHOOK_SECRET` , and `.env.example` omits them, so the API answers 400 "not configured".	`docker-compose.yml` , `docker-compose.prod.yml` ; `.env.example`
P-02	Confirmed issue	**BillDesk orders can never settle.** `PaymentsService.settle()` has no route, and `/api/payments/webhook` is now the Razorpay handler, so the BillDesk stub's callback gets 400. `POST /payments/orders` still creates BillDesk orders.	`payments.service.ts:400-492` ; `payments.controller.ts:62-76` ; `tests/billdesk-stub.mjs`

ID	Class	Finding	Evidence
P-03	Potential issue	**A concurrent verify and webhook can make one request 500** (unique `Subscription.orderID`). A Razorpay create-order failure returns 500 and leaves a CREATED order behind. The Razorpay HMAC comparison is not constant-time.	`payments.service.ts:128-148, 233-254` ; `razorpay.service.ts:60, 82, 98`
P-04	Missing implementation	**Payment has no further effect.** It only adds a `tblSubscription` row (gating self-apply): there is no receipt email, the role 6 "Subscription" is never assigned (and has no `tblSecRoles` row), the plan tier is not tied to experience, and employers cannot pay invoices online.	`payments.service.ts` ; `db/seed/tblSecRoles.psv`
F-01 ✔	Confirmed issue	**Employer registration fails when HR email is blank.** The form sends `emailHR: ''`, and `@IsOptional() @IsEmail()` rejects empty strings (400). The e2e fixture always fills it.	`apps/web/src/features/auth/pages/EmployerRegisterPage.tsx:38, 99` ; `apps/api/src/modules/auth/dto/auth.dto.ts:178-180`
F-02 ✔	Confirmed issue	**The legacy Q3 screens 403.** `/recruitment/q3/candidates`, `/interviews` and `/documents` are in the Q3 sidebar, but the endpoints behind them are `@Roles(QC1, QC2, Admin)`.	`apps/web/src/components/layout/menu.ts:109-111` ; `recruitment.controller.ts:36`
F-03 ✔	Confirmed issue	**Q1/Q2 "View/Download CV" fails with 401.** It opens `/api/recruitment/candidates/:id/resume` with `window.open` or `<a href>`, which sends no bearer header.	`apps/web/src/features/q1/pages/Q1CandidateProfilePage.tsx:138, 144, 277, 284` ; `apps/web/src/features/q2/pages/Q2ApplicantDetailPage.tsx:288-296`
F-04	Potential issue	**Job search filters may 400 against the real API.** axios serialises arrays as `employmentTypes[]=…`, Express 5's default "simple" query parser keeps that key, and `forbidNonWhitelisted` rejects it. The mocked e2e cannot show this.	`apps/web/src/lib/axios.ts` (no paramsSerializer); `apps/api/src/main.ts:36-41` ; `jobs/dto/jobs.dto.ts:61-78`
F-05	Confirmed issue	**The web app calls non-existent endpoints**: `/candidates/:id/profile` (the target of every "Share Profile"), `/companies/:id/reviews`, `/clients/:id/reviews`, `/jobs/salary-insights`, `/search`.	see API_DOCUMENTATION §18
F-06	Confirmed issue	**The home search keyword is dropped**: `JobSearchBar` sets `?designation=` while `JobSearchPage` reads `?q=`.	`features/jobs/components/JobSearchBar.tsx:23` ; `JobSearchPage.tsx:56`
F-07	Confirmed issue	**Notification preferences: PUT saves only 4 of 12 fields**, so the per-topic toggles revert on reload.	`candidates.service.ts:1523-1545` ✔
F-08	Confirmed issue	**Fake or cosmetic success.** The Contact form only simulates a delay. Referral "Invite sent" sends nothing, and `?ref=` is never read. Data export promises an emailed archive that is never produced. The resume "View" link points to `/files/resume` (SPA 404).	`features/public/pages/ContactPage.tsx:29-33` ; `ReferPage.tsx:42, 61-64` ; `ProfileAsideCards.tsx:150-156`
F-09	Confirmed issue	**Misleading or missing error handling.** Job apply shows "already applied" for every 400. Forgot-password has no error branch. Legacy interview Complete/Cancel fail silently. The legacy QC1 dashboard shows a skeleton forever on error. The bulk import shows a generic axios message.	`JobApplyPage.tsx:126-129` ; `ForgotPasswordPage.tsx:21` ; `recruitment/pages/InterviewsPage.tsx:58-62` ; `QC1DashboardPage.tsx:17, 38` ; `BulkImportPage.tsx:62`
F-10	Confirmed issue	**Q2 Reject / Send back / Forward have no confirmation or reason capture**, and the decisions are final.	`Q2ApplicantDetailPage.tsx:172-198`
F-11	Confirmed issue	**Dead links**: CommandPalette `/candidate/settings` ; PWA shortcut `/candidate/applied-jobs` ; Career canonical `/careers` ; the welcome email's link to `/profile`.	`components/CommandPalette.tsx:59` ; `apps/web/vite.config.ts:79` ; `CareerPage.tsx:22` ; `auth.service.ts:498`
F-12	Confirmed issue	**Wrong-default data.** The wizard defaults gender to 'M' when left blank. The employer bell always shows an unread dot. The portal unread badge ignores stored notifications.	`PersonalStep.tsx:116` ; `EmployerHeader.tsx:96-98` ; `hooks/useRealtimeNotifications.ts`
A-01 ✔	Confirmed issue	**Staff cannot log in by email**, only by username. Staff logins are written with NodeType 100, which the email-login path excludes.	`admin/staff-account.ts:40, 56` ; `prisma/seed.ts:269, 288` ; `auth.service.ts:197`
A-02	Confirmed issue	**Migrated legacy candidates cannot use the portal.** `SubscriberID` is null, so every `/candidates/me*` call returns 404 and they are stuck in onboarding.	`candidates.service.ts:138-146`
A-03	Confirmed issue	**Admin is listed on the employer routes and the company-review route but always gets 404** (it has no linked company).	`employers.service.ts:354-367` ; `recruitment.service.ts:539-552`
A-04	Confirmed issue	**Platform settings are stored but read by nothing** (maintenance mode, registration open, limits, SMTP fields). The settings page can also save defaults over stored values if loading fails.	`admin.service.ts:1097-1116` ; `features/admin/pages/AdminSettingsPage.tsx:130-147`

3.3 Validation & data consistency

ID	Class	Finding	Evidence
D-01	Potential issue	**No unique (JobID, SubscriberID) constraint.** The duplicate-apply check runs outside the transaction, so a double submit can create two applications. CvReferral and InterviewRound (mapId, roundNumber) also lack uniqueness.	`job-application.service.ts:70-78` ; `schema.prisma`
D-02	Confirmed issue	**Schema ↔ migration drift.** `tblClientInvoice` has a migration FK not declared in the schema; two indexes and the Institute FK actions exist only in migrations. `prisma migrate dev` would try to drop them.	`apps/api/prisma/migrations/20261005130000_client_invoices` , `…q2_matching_workspace` ; `schema.prisma:1646-1664`
D-03	Confirmed issue	**Missing range checks.** Job CTC and experience ranges are never checked (min ≤ max), and the bulk upload bypasses the CTC validators. Company profile fields lack IsEmail and MaxLength (oversized input → 500).	`employers.service.ts:679, 1855-1857` ; `employers.dto.ts:543`
D-04	Confirmed issue	**Prisma errors are not mapped**: FK, unique and not-found violations surface as 500 rather than 400/404/409.	`common/filters/http-exception.filter.ts:68-75`
D-05	Confirmed issue	**Many multi-step transitions are not atomic.** Examples are referToQ3, forwardToCompany, companyReview, createRound, submitResult, Q3 decide, generateOffer, employer decisions and profile updates. They are race-safe where conditional claims are used, but partial failures leave inconsistent state.	see DATABASE_SCHEMA "Data lifecycle"
D-06	Confirmed issue	**Audit gaps.** `cv.*` audits use entityId 0. There is no audit on job create/update/duplicate/bulk, change-password, auto-expiry, the Q3 document actions or the recruitment document review. The admin application view reads audit only for entity `JobSubscriberMapping` , so it shows almost no pipeline audit. Q3-path transitions write no candidate history.	`cv-referral.service.ts:90-96, 136-142, 197-203` ; `admin.service.ts:918`
D-07	Confirmed issue	**Query-building collisions.** In job search, `workMode` / `workModes` and `location` / `locations` / `states` overwrite each other, and full-text filters are case-sensitive. In the Q1 queue, the New tab ignores search, priority overrides the tab, and `?cvOnly=false` is read as true. The employer applicants export has only 10 rows, and the admin jobs export ignores `status` / `company` . The job detail shows the interview process as raw JSON.	`jobs.service.ts:136-148, 281-303, 554-557` ; `q1.service.ts:245-278` ; `q1/dto/q1.dto.ts:63` ; `exports.controller.ts:213` ; `exports.service.ts:168-192`
D-08	Potential issue	**Scoring compares ids from different masters** (subFunction vs designation, degree vs educationType) and uses current CTC as "expected", and Jaccard penalises extra skills.	`recruitment/scoring.service.ts:47-48, 194-207`
D-09	Potential issue	**Time zones are mixed.** Q3 uses IST explicitly; recruitment emails, Q1 "today", Q1 analytics and admin signups use server UTC.	`recruitment.service.ts:285-286` ; `q1.service.ts:197-198`
D-10	Potential issue	**`migrate-data.ts` is destructive and its inputs are stale.** It TRUNCATEs every table (including payments and audit) without a guard, and its `db/foreign-keys.psv` still holds stale education edges that would NULL valid data.	`apps/api/prisma/migrate-data.ts:125-173` ; `db/foreign-keys.psv`

3.4 Missing implementations (feature-level)

Area	Missing
Notifications	No code creates in-app/SSE notifications; SMS is never sent; job-alert and payment-receipt emails have no caller; the in-memory store breaks the "scale api=3" claim in `deploy/DEPLOYMENT.md`
Candidate	Withdraw application, reschedule request, advanced profile editor (commented out, so completion is capped below 100%), data export / deletion processing, privacy enforcement, referral invites and crediting, CV parsing, public profile
Employer	Team / sub-users, change password, messaging, notifications, settings pages (placeholders), online invoice payment, real meeting links (placeholder URL), branding UI
Staff	Q1 contact log UI; Q3 can't record a company rejection; Q3 offers have no resend/revise/withdraw; Q1 contact actions do not actually message the candidate
Platform	Settings enforcement, public blog from the CMS (no public endpoint), company reviews, salary insights, global search, OAuth (buttons disabled), file deletion from storage, invoice creation (invoices are only read)

3.5 Duplicate / conflicting business logic

Topic	Implementations	Recommendation
Round results	`InterviewRoundService.submitResult` vs `Q3InterviewsService.decide`	One decision service that writes all fields both read models need
Interview models	legacy `tblJobInterviewStatus` vs `tblInterviewRound`	Retire the legacy path
Document review	recruitment review (1/2, no history), Q3 verify/send-back (1/2 + history), employer review (1/3 + history + hand-off)	One vocabulary, one writer
Refer to Q3	`/recruitment/referrals` vs `/q2/applications/:mapId/forward`	Route all through Q2

Topic	Implementations	Recommendation
Company review	employer decision / interview request vs `/recruitment/referrals/:id/company-review` vs Q3 round-setup	Single path
Offer & joined	`/recruitment/offers*` vs `/q3/applications/:mapId/offer` and `/joined`	Single path that sets `joinedAt`
Candidate decision	Q1 screening (`tblSubscriberScreening`) vs legacy registration decision (`flgstatus`)	Pick one
Scoring weights & completeness	`scoring.service.ts` vs `shared/matching.ts` ; three completeness loaders (Q1, Q1 analytics, Q2)	Share one implementation
Staff UI	`/q1` , `/q2` , `/q3` (canonical) vs legacy `/recruitment/*` (still linked)	Redirect or remove the legacy screens
CSV writers	exports module (with formula-injection guard) vs two employer CSVs (without)	Reuse the guarded writer

3.6 Infra & configuration

ID	Class	Finding
I-01	Confirmed issue	The base `docker-compose.yml` never forwards `EMAIL_DRIVER` / `SMS_DRIVER` , so plain `docker compose up` logs emails instead of sending them, even with SMTP set. Registration OTP therefore cannot work on that path
I-02	Potential issue	Deploys build on the EC2 host and auto-apply migrations on start with no backup step or rollback
I-03	Improvement recommendation	nginx listens on :80 only with no HSTS/CSP; no explicit no-cache for the PWA service worker; Redis has no password (internal network only)
I-04	Improvement recommendation	`apps/api/.env.example` lists stale SQL Server `DB_*` variables and omits `RAZORPAY_*` , `THROTTLE_LIMIT_PER_MIN` , `STORAGE_*`
I-05	Improvement recommendation	`/api/health` always returns HTTP 200 even when degraded, and checks disk at `/` rather than the storage root

3.7 Performance (improvement recommendations)

- Employer applicants, Q2 applicants and analytics load every row and paginate in memory.
- Q3 `loadApps` loads every referred application on each dashboard, nav-count or report call.
- Q1 analytics issues about 3,000 queries.
- Full-text search computes `to_tsvector` per row with no expression index.
- Q2 and Q1 GET endpoints perform writes (score backfill, review rows, status changes).
- Hot FK columns lack indexes (`tblSecActiveSessions.SessionID` , `tblPaymentOrder.BDOrderID` , document tables).

3.8 Mobile responsiveness (static evidence only; runtime check needed)

- **Verified at runtime by the existing suite**: `tests/admin-e2e.mjs` checks admin pages for horizontal overflow at 320–1440 px. The Q2 Playwright spec covers the mobile drawer.
- **Static evidence**:
  - Every shell (public navbar, candidate portal, DashboardLayout, employer, Q1/Q2/Q3, admin) has a hamburger or drawer below `lg` . Only AdminShell's drawer has Escape handling, focus trap and scroll lock.
  - Q1 and admin tables switch to cards on phones. Q2 and Q3 tables scroll horizontally (min-width 714–1126 px), as do employer tables.
  - The quick search in the Q1/Q2/Q3 top bars is hidden below `md` .
  - `MobileBottomNav` exists but is not mounted.

---

4. Requires runtime verification

1. Job-search filter query arrays against the real API (F-04).
2. Razorpay end-to-end with real keys, including webhook delivery through nginx and the verify/webhook race (P-01, P-03).
3. A BillDesk sandbox run, if BillDesk is kept (P-02; README already flags this).
4. Email delivery with `EMAIL_DRIVER=smtp` on each compose path (I-01).
5. SSE behaviour through nginx (60 s `proxy_read_timeout` vs 30 s heartbeat) and with more than one API replica.
6. Q1/Q2 CV open/download (F-03) and the legacy Q3 screens (F-02) in a browser.
7. Prisma-error → 500 cases (D-04) and FK failures on bad master ids.
8. Concurrent apply / Q2 forward duplicates (D-01).
9. Mobile layouts of the Q2, Q3 and employer tables on real devices.
10. A full pipeline walk-through (apply → Q2 → Q3 → company → rounds → documents → offer → joined) mixing employer and Q3 actions, to observe W-01/W-06/W-07 end to end.

5. Suggested fix order

1. **Data exposure**: S-01, S-02, S-03, S-04 (restrict the generic file route, stop client-supplied logo keys, scope employer documents by application, escape email templates).
2. **Payments**: P-01 (forward the Razorpay env vars) and P-02 (remove or route BillDesk).
3. **Pipeline integrity**: W-01/W-06/W-07 (one decision path), W-02 (from-state guards; delete `PATCH /recruitment/pipeline/:id`), W-03 (enforce or document hand-offs).
4. **Visible breakages**: F-01, F-02, F-03, F-04, F-05, F-06, F-07, A-01.
5. **Tests**: add API tests for payments, the employer lifecycle, the Q2/Q3 services and a role-matrix test, then fix the CI duplication.